MahaSetu AI: MVP Documentation and Implementation Plan

Senior engineering documentation · Version 1.0 · 20 October 2026 · All departments are mocks, all data is synthetic

1. Purpose and MVP scope

One line. MahaSetu AI is an interoperability layer over existing Maharashtra department systems. A citizen or business applies once, tracks everything with one ID, and is warned about delays. It does not replace department systems and it does not approve applications. Officers decide.

What the MVP must prove. One submission fans out to several departments in different formats, survives a failed department, never duplicates, respects consent, and shows one honest status. If the demo story in section 3.4 runs end to end, the MVP is done.

In the MVP	Deferred until after the pilot
One login, four roles (citizen, business, officer, admin)	Real DigiLocker / API Setu identity
Rules-based approvals checklist, Marathi and English	Free-text AI answers beyond phrasing and Q&A over the rules
Document pre-checks using pre-extracted fields	OCR of real scanned documents
Consent per department with expiry and revoke	Consent receipts and DPDP rights portal
Submit once, one tracking ID, parallel send to 3 mock departments	Real department integrations (need an MoU)
Retry, dead-letter queue, idempotency	SMS, WhatsApp and email notifications
Unified timeline, derived status	Fast-track risk scoring
SLA warning, automatic grievance, escalation	Predictive delay models
Hash-chained audit log with verify	External audit anchoring service

In the MVP	Deferred until after the pilot
Officer queue and admin dashboard	Mobile native apps, offline mode

Non-goals. No new government portal for officers to live in, no replacement of department databases, no automated approvals.

2. Users and roles

Role	Who	Primary job	Sees
Citizen or business	Applicant, often on a basic phone, often Marathi-first	Apply once, track, fix problems	Own applications only
Officer	Clerk or officer in one department	Decide on tasks and ask for more information	Own department's tasks only
Admin	Nodal or IT cell staff	Watch health, retry failures, audit	Everything, read-mostly

Roles are enforced on the server for every query. The UI only hides what the server already refuses.

3. MVP user flow

3.1 Applicant flow (8 steps)

#	Step	Screen	API call	What happens	Failure the user sees
1	Log in	Login	POST /v1/auth/login	Token with role and language	Wrong login: "Email or password is incorrect" with a retry hint

#	Step	Screen	API call	What happens	Failure the user sees
2	Describe	Wizard: Describe	POST /v1/assistant/checklist	Rules file returns required approvals, each with a reason and rule ID	No rule matches: "Not sure. Please contact the department"
3	Checklist	Wizard: Checklist	(same response)	Approvals and documents listed, each says which department needs it	None
4	Upload	Wizard: Upload	POST /v1/validate	Missing or inconsistent fields flagged per field, in both languages	Name or address mismatch with the exact fields named
5	Consent	Wizard: Consent	POST /v1/consent	One card per department: data shared, purpose, Allow or Deny	Denied: plain explanation of what cannot proceed
6	Submit	Wizard: Submit	POST /v1/applications	Tracking ID returned within 2 seconds, sends happen in the background	Consent missing: 403 consent_required
7	Track	Tracking	GET /v1/applications/{id}/timeline	One timeline, every department in parallel, derived status	Department down: "Processing delayed, we are retrying"

#	Step	Screen	API call	What happens	Failure the user sees
8	Act and resolve	Tracking	POST /v1/applications/{id}/resubmit/{dept}	Fix only the rejected department, others stay approved	Wrong state: 409 invalid_transition

3.2 Officer flow

1. Log in and land on the queue, sorted by SLA due time, each row with a countdown and a text label for risk.
2. Open an application detail limited to their own department's task and the fields that department received.
3. Decide: approve, reject (reason required) or request more information. The decision is sent to the department system through its connector. The platform mirrors the resulting state when the department reports it.
4. The applicant is notified in the app on every state change.

3.3 Admin flow

1. Dashboard: average processing minutes per department, SLA breaches, slowest stages, connector health. Every chart title states its finding in plain words.
2. Failed calls: list of dead-lettered sends with a Retry button.
3. Audit: search by tracking ID, then press Verify to show the chain is intact.
4. Demo panel (only when DEMO_MODE is on): fail the next department call once, and shorten SLAs to 30 seconds.

3.4 Demo story: Ravi starts a small factory

1. Ravi logs in once. 2. He describes the factory (district, size, sector). 3. The assistant lists Industries, Pollution Control and Fire, each with the rule it came from. 4. He uploads synthetic documents. 5. Validation catches an address mismatch between ID proof and address proof, and he corrects it. 6. He allows data sharing for the three departments. 7. He submits once and gets one tracking ID. 8. One timeline shows all three departments. 9. The admin forces a Pollution Control failure, the retry succeeds and no duplicate appears. 10. The admin shortens the SLA, the officer gets a warning at 80 percent and a grievance is created at the deadline. 11. Fire rejects with a reason, Ravi

fixes and resubmits to Fire only. 12. The Pollution Control officer approves and Ravi is notified. 13. The admin runs audit verify. 14. The dashboard shows real timings from this run.

3.5 Error and empty states (design every one)

State	Message pattern	Action offered
Wrong login	What is wrong, no hint about which field	Try again, reset password
Session expired	"Your session ended. Please log in again"	Log in, return to the same screen
Upload too large or wrong type	Names the limit and allowed types	Choose another file
Department API down	"Processing delayed, we are retrying"	None needed; shows next retry time
Consent denied	Names the department and what cannot proceed	Change decision, or continue without that department
No applications yet	One sentence and one button	Start new application
No rule matches	"Not sure. Please contact the department"	Show department contact

4. Architecture

4.1 Layers

Layer	Components	Responsibility
Frontend	React app: citizen portal, officer queue, admin dashboard	Role-based screens, Marathi and English, no business rules
Backend services	FastAPI modules: identity, tracking, assistant and validation, workflow	Business rules, consent gate, derived status, audit

Layer	Components	Responsibility
Interoperability layer	Gateway, connectors, common data model, outbox worker, dead-letter queue	The only door to departments. One connector per department
Departments	Industries (nested JSON), Pollution Control (flat JSON), Fire (XML), Labour (CSV file drop)	Mocks with synthetic data. A real department replaces a mock by swapping only its connector
Data	PostgreSQL (all state, outbox, audit), optional Redis (cache and rate limits)	Single source of truth for the platform

4.2 Key design rules

1. **Every cross-department call passes the gateway.** The consent check, audit row and projection happen in one send function.
2. **The department is the system of record for task state.** The platform mirrors it by polling or webhook, so the officer console never becomes a competing portal.
3. **Status is derived, never stored.** One function turns task states into approved, action_needed, partly_approved, delayed, in_progress or draft.
4. **Submit is fast and sends are asynchronous.** Submit writes the application, tasks and outbox rows in one transaction and returns. A worker sends.
5. **Send what was consented to, nothing more.** One field list per department drives both the consent card and the outbound payload.
6. **Idempotency key is tracking ID, department and version.** Same key is a retry. A new version is a deliberate resubmission that updates the same department record.

4.3 Submit sequence

1. The browser calls POST /v1/applications with an Idempotency-Key header.
2. The backend checks consent for every named department. If any is missing, it returns 403 and creates nothing.
3. In one transaction it inserts the application, one task per department and one outbox row per task, and writes an audit row.
4. It returns 201 with the tracking ID.

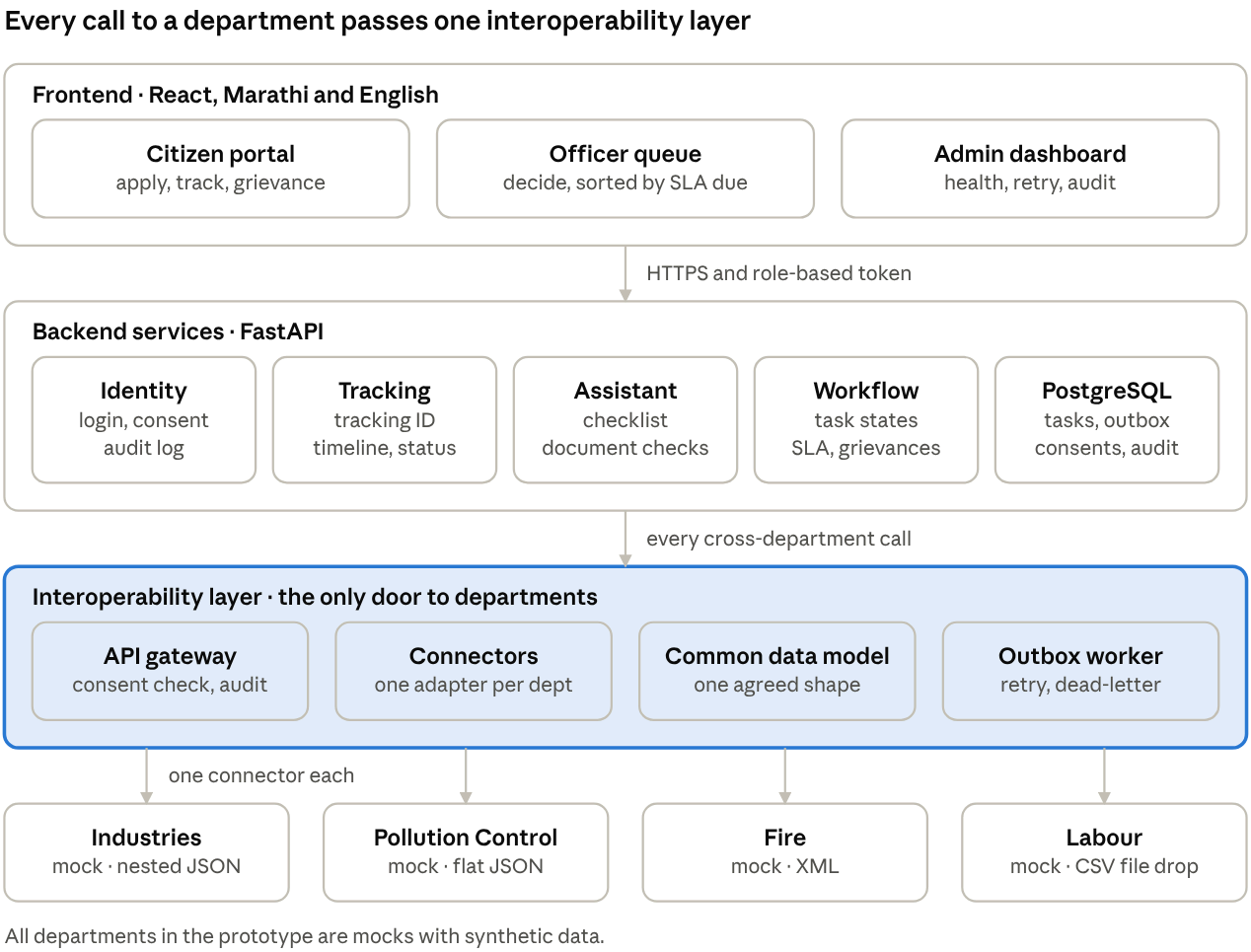
5. The worker claims due outbox rows (SELECT … FOR UPDATE SKIP LOCKED), re-checks consent, projects the fields, sends through the connector and records the department reference.
6. On failure it schedules the next attempt after 1, 2 and 4 seconds. After the fourth failed attempt the row goes to the dead-letter queue and the task state becomes dead_letter.
7. A sync job polls each department for task state and applies only allowed transitions, writing an audit row for each.
8. A one-minute SLA job warns at 80 percent, and on breach creates one grievance and raises its escalation level.

4.4 Trust boundaries

Browser to backend (HTTPS, short-lived signed token, role re-read from the user record). Backend to each department connector (consent, projection, mocks only until an MoU exists). Backend to the language-model service (no database or tool access, no personal data in prompts, answers only from the rules file and cites the rule ID).

4.5 Architecture diagram

The diagram below shows the four layers and the single door to the departments.



architecture · 4 layers, PostgreSQL store, 4 mock departments

The backend reaches each department only through the gateway and its connector, so a real department replaces a mock by changing only its connector.

5. Technical stack

Concern	Choice	Why	Rejected
Frontend	React with Vite, React Router, TanStack Query	Fast to build, route guards per role, cache and retries for server data	Heavy frameworks the team does not know
i18n	i18next, one JSON file per language	Every label and error in Marathi and English, missing-key check in CI	Hard-coded text

Concern	Choice	Why	Rejected
Backend	Python FastAPI, Pydantic	Typed validation, OpenAPI generated from code	Flask without schema
Database	PostgreSQL	Transactions, row locks, JSONB for project details	NoSQL, cannot give the outbox guarantees
Queue	Postgres outbox with SKIP LOCKED	One less moving part, survives restarts, atomic with the application write	Redis-only queue that loses jobs on restart
Cache and limits	Redis, optional in MVP	Rate limiting and login lockout counters	Required Redis for correctness
Auth	Signed 15 minute tokens, argon2id password hashes	Simple, testable, role re-read on each request	Long-lived tokens
AI assistant	Rules file first, LLM only to phrase and handle free text, off by switch	A wrong approval answer causes real harm	LLM answering unaided
Charts	Recharts	Titles that state findings, accessible labels	Heavy BI tools
Packaging	Docker Compose, one command start	Fresh-machine test	Manual setup
Tests	pytest or unittest, Playwright for end to end	Same story as the demo	Manual only

Configuration lives in environment variables with a documented .env.example: DATABASE_URL, REDIS_URL, JWT_SECRET, TOKEN_MINUTES, LLM_API_KEY, LLM_ENABLED, SLA_FILE, RULES_FILE, DEMO_MODE (must be off outside demos), AUDIT_HMAC_KEY.

6. Backend specification

6.1 Modules

Module	Responsibility
auth	Login, token, role dependency, rate limit and lockout
consent	Grant, list, revoke, active-consent check with expiry
applications	Create, list, timeline, resubmit
assistant	Rules lookup, rule citation, "not sure" answer, optional LLM phrasing
validation	Required fields, document types, cross-document identity match with Devanagari and Latin name matching
workflow	Task state machine, allowed transitions, department sync
outbox and gateway	Claim, send, backoff, dead-letter, API health logging
sla	Warn, breach, grievance, escalation, clock pause while waiting on the applicant
analytics	Averages per department, breaches, slowest stages, API health from real timestamps
audit	Hash-chained HMAC log, verify, head anchor
connectors	One adapter per department with to_canonical, encode, send and fetch_status

6.2 API surface (all under /v1, JSON over HTTPS, bearer token)

Method and path	Role	Purpose	Notable errors
POST /auth/login	public	Token, role, department, language	401 invalid_credentials

Method and path	Role	Purpose	Notable errors
POST /assistant/checklist	applicant	Approvals with reason, rule ID and documents	422 invalid_input
POST /validate	applicant	Field-level issues in English and Marathi	422 invalid_input
POST, GET /consent; DELETE /consent/{id}	applicant	Grant, list, revoke	404 not_found
POST /applications	applicant	Create, returns tracking ID in under 2 seconds	403 consent_required
GET /applications, GET /applications/{id}	applicant	Paged list and derived status	401
GET /applications/{id}/timeline	owner, officer, admin	Events, filtered to the officer's own department	403 forbidden
POST /applications/{id}/resubmit/{dept}	owner	Resend corrected data to one department	409 invalid_transition
POST /officer/tasks/{id}/decision	officer of that department	Approve, reject with reason, more_info; sent through the connector	403 wrong_department

Method and path	Role	Purpose	Notable errors
POST /grievances	applicant	Raise a grievance against a tracking ID	404 not_found
GET /analytics	admin	Averages, breaches, slowest stages, API health	403
GET /admin/failed-calls; POST /admin/failed-calls/{id}/retry	admin	Inspect and retry dead letters	404
GET /admin/audit; GET /admin/audit/verify	admin	Search rows, verify chain	403
POST /admin/demo/fail-next; POST /admin/demo/sla	admin, demo mode	Demo switches	403

One error shape everywhere, so the frontend can show it in the user's language: an error object with code, message_en and message_mr. Pagination uses limit and cursor, default 25, maximum 100.

6.3 Data model

Table	Key columns	Notes
users	id, email (unique), password_hash, role, department, language	Officers have a department
applications	tracking_id, user_id, service_type, project (JSONB), created_at	No status column: status is derived
dept_tasks	id, tracking_id, dept, dept_ref_id, state, submission_version, SLA start, budget, pause fields, warned, breached, escalation_level	Unique (tracking_id, dept)

Table	Key columns	Notes
outbox	id, task_id, idem_key (unique), payload (encrypted), state, attempts, next_attempt_at, claimed_at	Written in the same transaction as the task
dead_letter	outbox_id, tracking_id, dept, error, attempts, retried_at	Admin retry reuses the same idempotency key
documents	id, tracking_id, type, reference, fields (JSONB), validation_status	References only, never copies
consents	id, user_id, dept, purpose, granted_at, expires_at, revoked_at	Kept after revoke
grievances	id, tracking_id, task_id, reason, escalation_level, resolved_at	Created automatically on breach
audit_log	id, actor, action, entity, ts, prev_mac, mac	App role can insert and read only
api_health	connector, status, latency_ms, last_error, checked_at	Feeds the admin dashboard

6.4 Task state machine

submitted → received → in_review → approved, rejected or more_info. A rejected or more_info task returns to in_review after the applicant resubmits to that department only. A send that fails four times goes to dead_letter, and an admin retry returns it to submitted. Any other change is refused with 409 invalid_transition. SLA warned and breached are flags, not states.

Derived application status. approved if every task is approved; action_needed if any task is rejected or more_info; delayed if any task is dead_letter; partly_approved if some are approved; otherwise in_progress; draft when there are no tasks.

6.5 Security and privacy checklist

- Role and department checked on every query, not only in the UI.
- Consent checked at submit and again at send time, with expiry and revocation in the query.
- Personal fields encrypted at rest, documents passed as references, logs carry identifiers only.

- Parameterised queries, input validation, upload type and size limits, files stored outside the web root.
- Login rate limit and temporary lockout, signed short-lived tokens.
- Audit rows protected by HMAC and a sequence number. Publish the daily head hash outside the database to detect truncation.
- Synthetic data only in the prototype. Test data wiped before any public demo.

7. Frontend specification

7.1 Structure

Area	Contents
Pages	Login, Dashboard, NewApplication (wizard), Tracking, OfficerQueue, OfficerDetail, AdminDashboard, ApiHealth, FailedCalls, AuditLog
Shared components	LanguageSwitch, ProgressSteps, ChecklistCard, DocumentUploader, ConsentCard, StatusBadge, StatusTimeline, SlaBadge, AssistantChat, ErrorBanner, EmptyState
State	Token and role in memory, server data through TanStack Query, wizard draft in local component state so a refresh does not lose the step
Routing	A route guard sends each role to its own home screen; unknown or forbidden routes show a plain message
i18n	One file per language, keys for every label and error, CI fails on a missing key
API client	One module, attaches the token, sends an Idempotency-Key on submit, maps the error shape to a localized banner
Accessibility	Status is text plus icon, visible focus, labels on every input, works with large system fonts

7.2 Frontend behaviours that matter

- **Submit button disables after one tap** and reuses the same Idempotency-Key if the user taps again or the network retries.
- **Timeline polls every 15 seconds** while the tab is visible, and stops when hidden.
- **Optimistic nothing:** status always comes from the server, since it is derived.
- **Resilience:** a failed request shows the localized error with a retry button and never a blank screen.

8. UI and UX design

8.1 Principles

1. One task per screen, with a progress bar: Describe, Checklist, Upload, Consent, Submit.
2. Language switch in the header on every screen, with the choice remembered.
3. Plain words, short sentences, no jargon. A first-time user finishes without help.
4. Show why before asking: every document request names the department that needs it.
5. Never block silently. Every error says what is wrong and how to fix it.
6. Mobile first: single column, large tap targets, works on a small basic phone.
7. Status is words plus icon, never colour alone.

8.2 Status vocabulary

Status	Icon	English	Marathi (needs native review)
in_progress	hourglass	In progress	प्रक्रियेत
partly_approved	half circle	Partly approved	अंशत: मंजूर
action_needed	warning triangle	Action needed	कृती आवश्यक
delayed	clock	Delayed, we are retrying	विलंब, पुन्हा प्रयत्न सुरू
approved	check mark	Approved	मंजूर

Status	Icon	English	Marathi (needs native review)
draft	pencil	Draft	मसुदा

Task states shown in the timeline: submitted (सादर), received (प्राप्त), in review (तपासणीत), rejected (नाकारले), more information needed (अधिक माहिती हवी), approved (मंजूर).

8.3 Screen specifications

Screen	Key elements	UX detail
Login	Email, password, language switch	Large fields, show-password toggle, clear error
Dashboard	List of applications with tracking ID, status badge, last update	Tracking ID at the top of every application; empty state with one button
Wizard: Describe	Factory name, district, size, sector	Dropdowns instead of typing where possible
Wizard: Checklist	Approvals, reason, documents required	Each approval names its rule ID in small text
Wizard: Upload	Per document uploader, live validation	Field-level messages beside the field, in the chosen language
Wizard: Consent	One ConsentCard per department listing data shared and purpose	One clear Allow or Deny per department, no pre-ticked boxes
Wizard: Submit	Summary and one Submit button	Tracking ID shown prominently on confirmation, copy button
Tracking	Parallel timeline per department, SLA badge, grievance form, assistant chat	Partly approved wording explains which department needs what
Officer queue	Rows sorted by SLA due time, countdown, risk label	Breach risk highlighted with a label, not only colour
Officer detail	Own department's fields, decision actions	Reject needs a reason; more_info lists the documents wanted

Screen	Key elements	UX detail
Admin dashboard	Processing time, bottlenecks, breaches, API health	Each chart title states the finding in a plain sentence
Failed calls	Dead-letter list	Retry button with confirmation
Audit	Search and Verify	Verify shows OK or the first bad row

8.4 Visual system

- **Type:** one clear sans-serif that supports Devanagari, base size 16 px or larger, line height at least 1.5.
- **Targets:** tap targets at least 48 px, 8 px spacing between them.
- **Colour:** text contrast at least 4.5 to 1, one accent colour for primary actions, colour never the only signal.
- **Layout:** single column under 640 px, two columns for officer and admin screens on desktop.
- **Content:** Marathi strings written by a native speaker and reviewed again before every release.

9. Implementation plan

9.1 Repository layout

A docker-compose.yml at the root; backend/app with main, db, models, auth, consent, audit, gateway, outbox, workflow, sla, assistant, validation, rules (approvals_rules.json and sla.json) and connectors; mock_depts for the four mocks; frontend/src with pages, components and i18n (mr.json, en.json); tests; and an evidence folder for interviews, timings and the failure log.

9.2 Build phases (vertical slice first)

Phase	Scope	Done when
0. Foundation	Compose stack, schema, seed users, health route	One command starts everything on a clean machine

Phase	Scope	Done when
1. Vertical slice	One mock department: login, consent, submit, outbox send, sync, timeline, officer decision, derived status	A user submits, the officer decides, the status updates, with tests
2. Trust	Hash-chained audit with verify, rate limit, role tests	A send without consent is blocked, a revoked consent stops later sends, an edited audit row fails verify
3. Interoperability	Add Pollution (flat JSON) and Fire (XML), retry and dead-letter, failure switch	A forced failure retries and succeeds with no duplicate; one rejection leaves other approvals intact
4. Visibility	Labour file drop, SLA worker, admin dashboard, failed-call retry	A 30 second SLA produces a warning then an automatic grievance
5. Intelligence and experience	Rules checklist, validation with name match, assistant with citations, full UI and Marathi	The 30 to 50 question set is scored and five real users have tried it

Rule: the demo story in section 3.4 must run end to end after phase 4. Anything after that is optional. Cut the fast-track risk flag and notifications beyond in-app first if behind.

9.3 Definition of done

1. Every phase test passes from a clean docker compose up.
2. Timed test: 95 percent of read calls under 1 second, submit under 2 seconds, with 50 seeded applications.
3. Load test: 50 simultaneous users and 1,000 applications with no errors.
4. No real personal data or credentials in the repository.
5. The README states that departments are mocks with synthetic data and that real integration needs an MoU and an authorised pilot.

10. Testing strategy

Level	What it proves	Examples
Unit	Mapping, status function, rule lookup, name matching	All status cases, Patil equals पाटील
Contract	Every connector passes one shared test file against its mock	New department means write one adapter and pass the tests
Integration	Consent gate, idempotency, retry then dead-letter, audit verify, role checks	Revoked consent blocks send; corrected resubmit reaches the department without a duplicate
End to end	The full demo story with one forced failure and one SLA breach	Runs in one command and prints timings
Assistant evaluation	Accuracy and correct "not sure" on 30 to 50 questions including hostile prompts	Record accuracy and refusal rate
Usability	Five real users, including a Marathi-first and a low-digital-literacy user	Record completion, time, where they got stuck and one change made

Keep every failure and its fix in the evidence folder. One becomes the honest failure on the project page.

11. Risks and open decisions

Risk	Mitigation
Scope too large for the time	Vertical slice first, cut list defined in section 9.2
Wrong Marathi wording	Native-speaker review of every message before release
Demo failure on the day	Seed data, failure switch, SLA fast-forward, recorded backup video

Risk	Mitigation
Real portals have no open APIs	Mocks modelled on real flows; connector design allows a real plug-in during the pilot
Audit chain proves edits but not full-table deletion	Publish the head hash outside the database daily
A failed resubmit shows only in the dead-letter list	Known gap; add a dead_letter path for resubmits or derive delayed from dead outbox rows

Open decisions to settle with the department: which three or four services the pilot covers and who owns each rule, who the nodal officer is, which identity and document services are available and on what terms, the retention period for audit and consent records, who approves Marathi wording, the SLA each department really commits to, where the pilot is hosted, and how the Digital Personal Data Protection Act 2023 applies to purpose limitation, revocation of data already sent and data-principal rights.

Reference implementation. The tested core logic (status function, consent gate, outbox and retry, hash-chained audit, SLA worker, connectors with field projection, name matching) is in the companion file SPEC_FIXES.md.